CloudDesk Technologies

Backup and Disaster Recovery Policy

1. Authority, scope and ownership

SYNTHETIC / DEMO - document control

CD-BDR-001 | Version 1.0 | Fictional effective date: 2026-10-22 | Next review: 2027-10-22. Accountable approver: CTO; approval not recorded. Owner and coordinator: Engineering Lead. Review annually and after material changes, incidents or exercises. Editable JSON is the source of truth for this PDF.

Status and limits

CloudDesk Technologies is a fictional 75-person B2B SaaS vendor. All requirements here are proposed SYNTHETIC / DEMO assumptions, not operating facts. This model-authored policy has review_status: requires_user_review. No deployed schedules, implemented controls, actual restoration tests, successful recovery history, SLA, certification or legal compliance is claimed. No live contact directory, staffed recovery team or guaranteed response time is assumed.

Scope and ownership

Scope covers customer databases, tenant objects and attachments, production configuration, infrastructure definitions, scoped logs, SaaS dependencies and recovery documentation. System owners identify authoritative data, dependencies, exclusions and recovery procedures; Platform Engineering would implement assigned technical controls. Engineering Lead coordinates inventories, tests and remediation; CTO approves objectives, resources and residual risk. Coverage of each asset must be verified before adoption; this is not an actual backup inventory.

Related policy authority

Preserve access_control_policy.pdf, encryption_key_management_policy.pdf (CD-ENC-001), information_security_policy.pdf (CD-ISP-001) and incident_response_plan.pdf (CD-IRP-001). These remain authoritative in their domains. This policy adds proposed recovery procedures without weakening access, key lifecycle, risk governance or incident authority. Record any discovered conflict for Engineering Lead and CTO resolution before adoption.

Backup and Disaster Recovery Policy

2. Inventory, impact assessment and proposed schedules

Backup inventory and classification

For each dataset record system owner, source, business purpose, tenant scope, highest applicable classification, backup method, location/account/region, copy dependencies, key identifier/version, authorized restore role, vendor and runbook. Classify Public, Internal, Confidential or Restricted under CD-ISP-001. Record coverage gaps, exclusions, deletion behavior, verification method, holds and proposed frequency/retention approval status. Do not place secret key material or credentials in the inventory.

Business impact analysis and objectives

System owners propose a business impact analysis (BIA) covering outage harm over time, data-loss tolerance, customer and contractual obligations, dependency failures, staffing, costs and recovery order. Engineering Lead reviews assumptions and feasibility; CTO approves recovery time objectives (RTO) and recovery point objectives (RPO) after impact assessment. RTO concerns time to restore service; RPO concerns tolerable loss of recent data. Both remain TBD pending BIA, business and contractual review; no numerical targets or availability guarantees are supplied.

Proposed frequency and retention - TBD

Backup frequency and retention are TBD pending BIA/business and contractual review. Owners propose risk-based values per dataset using change rate, sensitivity, loss tolerance, recovery cost and obligations; Engineering Lead reviews and CTO approves before deployment. Record approved values and rationale separately. No daily, weekly or other deployed backup schedule or fixed retention period is asserted. Snapshots and replication require independent recoverability assessment; replication can propagate corruption and is not by itself proof of a recoverable backup.

Retention, holds and disposal

Reconcile backup expiry, customer deletion commitments, legal or incident holds and vendor deletion behavior with appropriate advice. Record any delayed deletion in retained copies and prevent unintended reintroduction during restore. Restrict held copies and associated keys; dispose only after approved retention and hold release, with evidence. Preserve the separate minimum 12-month retention for KMS audit logs; it is not a backup retention period or a universal records rule.

Backup and Disaster Recovery Policy

3. Encryption, keys and backup protection

Encryption and grant separation

Encrypt all production backups and snapshots at rest with AES-256; protect backup transfers with TLS 1.2 or TLS 1.3. Use managed KMS and backup-specific key grants separate from ordinary application access. Key-encryption keys remain non-exportable in KMS. Separate key administration from routine data access; key administrators receive no default decrypt permission. Engineering Lead approves grants. Use unique user accounts and multi-factor authentication for administrative access; review permissions and key grants every quarter and revoke terminated employee access within 24 hours.

Key versions and recoverability

Rotate symmetric key-encryption keys at least every 12 months under CD-ENC-001. Rotation alone does not re-encrypt historical data. Retain restricted access to older key versions for the full lifetime of dependent retained backups, including legal or incident holds. Inventory KMS availability, account, region, identity and version dependencies; verify authorized decrypt access in restore checks. Never destroy a key merely because its active version rotated. Destroy only after dependent retention ends and recovery checks show no remaining need, with Engineering Lead and CTO approval and destruction evidence.

Compromise and emergency access

On suspected key compromise immediately open an incident, revoke affected identity grants and disable compromised key versions where safe. Provision replacement keys and assess exposure, historical re-encryption and backup recoverability before destructive action. CTO authorizes temporary emergency decrypt access with logging and next-business-day review. Use trusted identities and recovery paths; do not reconnect compromised grants to obtain a restore. Review KMS administrative and decrypt audit events monthly and after incidents, retaining them at least 12 months in restricted encrypted storage.

Proposed isolation and immutability controls

Proposed controls include separate recovery identities, restricted deletion privileges, isolated backup accounts or failure domains, and provider-supported immutable or offline copies where justified by risk. Engineering Lead must validate provider semantics, retention locks, recovery access and cost before adoption. No immutability, air gap, separate-region copy or ransomware resistance is asserted as implemented. Test whether an attacker controlling production could alter backups or keys; escalate uncovered common failure paths and document compensating safeguards.

4. Disaster activation and safe restoration

Declaration and alternate communications

Engineering Lead assesses disruption, affected tenants, dependency availability and likely recovery needs under CD-IRP-001 severity rules; escalate critical service loss, destructive activity or key/backup compromise promptly to CTO. CTO authorizes disaster declaration, material service shutdowns, resources and material residual risk; record scope, rationale, time and delegated authority. Urgent reversible containment follows the incident plan. If normal accounts or messaging are unavailable or suspect, use separately verified alternate contacts and a restricted decision log. Contacts and substitutes require human validation before adoption.

Dependency-led restoration sequence

Owners document a dependency graph and propose an order: establish trusted identity and administrative access, network and KMS connectivity; recover validated infrastructure and configuration; restore consistent databases and objects; reconcile queues, indexes and dependent services; then validate and reconnect in phases. This is a planning sequence, not an assumed deployed architecture. Confirm vendor prerequisites, clean credentials, backup availability, key versions and recovery environment before each step. Record recovery points and dependencies; pause if prerequisite integrity or authorized decrypt access cannot be established.

Safe recovery after a cyber incident

Coordinate containment, evidence preservation and eradication through CD-IRP-001. Assess compromise window and backup provenance; select a candidate recovery point outside known corruption while documenting uncertainty. Scan and restore in isolation using trusted tools and rebuilt systems, remove persistence and replace compromised credentials. A recent or decryptable backup is not proof of safety. Preserve incident evidence where safe; do not overwrite original evidence or destroy keys blindly. Engineering Lead verifies containment; CTO approves material residual risk and return of critical service.

Tenant integrity and service gates

Before reconnection, system owners verify hashes or application-level integrity, transactional consistency, tenant boundaries, permissions, schema compatibility, deletion/hold reconciliation and representative customer workflows. Reconcile replayed events and duplicate writes without exposing one tenant to another. Record gaps, actual elapsed time and recoverable data point against approved objectives when available; do not promise an unapproved RTO/RPO. Define phased monitoring, rollback and stop criteria. Failed checks or recurrent indicators stop release and reopen investigation; external communications require CTO authorization and case-specific notification assessment.

Backup and Disaster Recovery Policy

5. Restore testing, continuity exercises and dependencies

Representative quarterly encrypted restore tests

Test a representative encrypted restore at least quarterly, recording data integrity, authorized key access and recovery outcome. Plan risk-based coverage across datasets, backup types and key versions over successive tests; do not imply every backup is restored every quarter. Use isolated environments, synthetic data where feasible and restricted handling for necessary customer data. Capture source/backup ID, recovery point, key version, operator authorization, checks performed, elapsed time, failures and limitations. Reconcile results with approved objectives without treating a test as an SLA or proof of all-system recoverability.

Negative recovery scenarios and remediation

Exercise missing or disabled keys, denied decrypt grants, unavailable KMS/provider, corrupted or incomplete copies, inconsistent database/object recovery points, compromised credentials and cross-tenant access attempts. Expected response is to stop unsafe restoration, preserve evidence, escalate to Engineering Lead/CTO and use a validated alternative or document inability to recover. Never bypass authorization or suppress failed integrity checks. Assign findings, owner, due date and retest evidence; successful extraction of this document is not a restoration test.

Annual continuity exercises are separate

Exercise continuity scenarios at least annually and after material changes under CD-ISP-001; coordinate incident exercises under CD-IRP-001. Cover unavailable responders, alternate communications, cloud/identity outage, vendor failure, ransomware, customer impact and decision authority. Record participants, assumptions, decisions, gaps and corrective actions. An annual tabletop does not replace a representative quarterly encrypted restore; a restore test does not by itself satisfy the broader annual continuity exercise. No exercise or restoration is claimed completed.

Vendor and shared dependencies

Owners assess cloud storage, KMS, identity, DNS, SaaS exports, support availability, regional dependencies and provider recovery/deletion limitations. Assess vendors before use; Engineering Lead reviews and CTO accepts material residual risk. Reassess critical vendors annually and after material changes or incidents. Verify contracts, export portability, recovery responsibilities, contacts and exit dependencies; provider replication, assurances or advertised recovery targets do not establish CloudDesk recoverability. Record inaccessible vendor data and recovery gaps in the risk register.

Backup and Disaster Recovery Policy

6. Changes, exceptions and review evidence

Change approval and risk governance

Before material architecture, backup method, retention, key, vendor or recovery-runbook changes, system owners assess impact on coverage and recoverability. Engineering Lead reviews proposed changes, dependencies, validation and rollback; CTO approves material risk and revised objectives before adoption. Update inventories and runbooks and record validation evidence. Coordinate risk assessments at least annually and before material service changes or onboarding scoped vendors; review open risks quarterly, with CTO acceptance of residual risk and escalation of overdue high-impact actions.

Exceptions and emergency deviations

Before deviation, owner records affected assets/data, requirement, rationale, risk, compensating safeguards, responsible owner and expiry. Engineering Lead assesses and CTO approves or rejects. Exceptions expire within 90 days and are reviewed monthly; renewal requires fresh assessment and approval. Emergency deviations require an incident record and CTO review by the next business day. CD-ENC-001 remains authoritative for encryption exceptions and destructive key approvals. This sample asserts no active exceptions or approvals.

Expected evidence artifacts

Expected records include backup inventory and coverage map; BIA and objective approvals; proposed then approved schedules/retention; configuration and access/grant reviews; backup job outcomes and failure escalation; key-version dependency checks; restore reports and integrity results; continuity exercise findings; incident decisions; vendor assessments; change/exception approvals and corrective-action closure. Restrict records with ownership, version history, approved retention and holds. No completed evidence artifacts are supplied. Preserve KMS audit-log retention without extending that minimum to all records.

Human review and adoption gate

Human reviewers must validate staffing, substitutes, declaration authority, inventories, proposed isolation/immutability, key access and recoverability, vendor limitations, BIA, customer contracts, notification obligations and resource feasibility. Engineering Lead reviews annually and after material changes, incidents or exercises; record feedback and CTO approval before operational adoption. Approval_status: not_recorded; review_status: requires_user_review. This is Policy 5 of an intended eight-policy fictional collection, not an approved recovery plan or compliance attestation.